

Vulnerability Assessment & Penetration Testing Report

Client: Test Client | Project: Security Assessment | Date: 2026-08-17

Executive Dashboard Summary

Health Grade	Total Findings	Overall Risk	Compliance Avg
F	4	10.0 / 10	60.0%

Executive Overview

During the security assessment conducted for Test Client under project 'Security Assessment', a total of 4 unique security vulnerabilities were identified across the target scope.

Overall Security Posture Rating: CRITICAL (Health Grade: F)
Breakdown: 2 Critical, 1 High, 0 Medium, 1 Low, and 0 Informational issues.

Immediate executive intervention is strongly advised to address high-severity vulnerabilities before production exposure.

Regulatory Compliance Posture

Standard Framework	Violations	Pass Score	Status
PCI-DSS 4.0	4	60.0%	NON-COMPLIANT
HIPAA	4	60.0%	NON-COMPLIANT
GDPR	4	60.0%	NON-COMPLIANT
ISO 27001	4	60.0%	NON-COMPLIANT

Detailed Vulnerability Findings (4)

#1. SQL Injection in Search Query Parameter [CRITICAL]

Location: <https://app.acme.com/search.php?q=test' OR 1=1--> | CVSS: 9.5 | OWASP: A05:2025 - Injection

Description: Database error 'syntax error near OR 1=1' was returned, and arbitrary database extraction was demonstrated. Parameter 'q' is concatenated directly into SQL queries without sanitization.

Remediation (Immediate (within 24 hours)): Use parameterized SQL queries (prepared statements) for all database operations.

#2. AWS EC2 Instance Metadata SSRF Leak [CRITICAL]

Location: <https://api.acme.com/proxy?url=http://169.254.169.254/latest/meta-data/iam/security-credentials/> | **CVSS:** 9.1 | **OWASP:** A01:2025 - Broken Access Control

Description: Server-Side Request Forgery allows accessing AWS IMDSv1 internal endpoint at <http://169.254.169.254/latest/meta-data/>

Evidence / PoC:

```
Curl Command: curl -X GET
'https://api.acme.com/proxy?url=http://169.254.169.254/latest/meta-data/iam/security-credentials/'
Extracted Findings: AccessKeyId: ASIAIOSFODNN7EXAMPLE, SecretAccessKey:
wJalrXUtnFEMI/K7MDENG/bPxrFiCYEXAMPLEKEY
```

Remediation (Immediate (within 24 hours)): Enforce IMDSv2 and restrict outbound HTTP requests to internal cloud metadata endpoints.

#3. Broken Object Level Authorization (BOLA / IDOR) [HIGH]

Location: <https://api.acme.com/api/v1/users/1024/profile> | **CVSS:** 7.5 | **OWASP:** A01:2025 - Broken Access Control

Description: By modifying the user ID parameter from 1024 to 1025, the application returns sensitive PII records of another tenant user without authentication errors. The application fails to enforce object-level authorization checks when accessing user profiles via numeric ID parameters.

Remediation (High Priority (within 7 days)): Enforce server-side authorization checks on all REST endpoints. Implement proper access control checks validating that the authenticated user owns the requested object ID.

#4. Missing Strict-Transport-Security (HSTS) Header [LOW]

Location: <https://app.acme.com> | **CVSS:** 3.4 | **OWASP:** A04:2025 - Cryptographic Failures

Description: HTTP Strict Transport Security header is missing, allowing potential Man-in-the-Middle SSL stripping attacks.

Remediation (Low Priority (within 30 days)): Configure HTTP Strict-Transport-Security response header with max-age >= 31536000 and includeSubDomains.